

MFR du Néracais

Apprendre aujourd'hui, construire demain

Procédure interne de gestion des violations de données personnelles

Article 33 et 34 du RGPD

MFR CFA Barbaste — 200 route de Bordeaux — 47230 Barbaste
Version 1.0 — Septembre 2026

Document interne — À porter à la connaissance du personnel

1. Qu'est-ce qu'une violation de données ?

Organisme concerné : Maison Familiale Rurale Éducation Orientation — MFR du Néracais, association loi 1901, SIREN 782198931, N° de déclaration d'activité 75470139547, UAI 0470781U, certification Qualiopi n° 2026/118673.1 (AFNOR Certification), siège au 200 route de Bordeaux — 47230 Barbaste.

Selon l'article 4.12 du RGPD, une violation de données à caractère personnel est une violation de la sécurité entraînant, de manière accidentelle ou illicite :

- La destruction de données personnelles
- La perte de données
- L'altération de données
- La divulgation non autorisée de données
- L'accès non autorisé à des données

Exemples concrets

Type	Exemples
Confidentialité	Envoi d'un courriel à la mauvaise personne contenant des données personnelles ; publication involontaire d'un fichier ; accès d'un tiers non autorisé
Intégrité	Modification non autorisée de données ; altération d'un fichier suite à un virus ; corruption de la base de données
Disponibilité	Perte définitive d'un fichier ; ransomware chiffrant les données ; suppression accidentelle sans sauvegarde ; vol d'un ordinateur

2. Obligations de la MFR en cas de violation

Deux obligations peuvent s'imposer

1. Notifier la CNIL dans un délai de 72 heures suivant la prise de connaissance (article 33 RGPD), SAUF si la violation n'est pas susceptible d'engendrer un risque pour les droits et libertés des personnes.
2. Informer les personnes concernées dans les meilleurs délais (article 34 RGPD), UNIQUEMENT si la violation est susceptible d'engendrer un risque ÉLEVÉ pour leurs droits et libertés.

Dans tous les cas, la MFR doit documenter TOUTES les violations dans un registre interne (article 33.5 RGPD), qu'elles soient notifiées ou non.

3. Procédure interne — Étape par étape

Étape 1 — Détection et signalement immédiat

Toute personne (salarié, stagiaire, intervenant) constatant ou soupçonnant une violation de données doit alerter IMMÉDIATEMENT la Directrice :

- Par téléphone en cas d'urgence
- Par courriel en second recours
- Sans attendre — même en cas de doute
- Sans tentative de dissimulation



Un signalement rapide n'est jamais une faute

Même si le salarié est à l'origine de la violation (erreur, négligence), le signalement rapide est une aide et sera valorisé. À l'inverse, la dissimulation aggrave la faute.

Étape 2 — Constatation et documentation initiale

Dès réception du signalement, la Directrice documente les faits :

- Date et heure de la découverte
- Date et heure supposées de la survenance
- Personne ayant signalé
- Nature de l'incident (perte, vol, divulgation, altération, destruction)
- Circonstances et cause supposée
- Périmètre : quels traitements, quels systèmes, quelles catégories de données

Étape 3 — Mesures d'urgence

Dans les heures qui suivent, la Directrice met en œuvre les mesures conservatoires :

- Isoler le système compromis (déconnexion, changement de mot de passe)
- Faire cesser la fuite (rappel de courriel mal adressé si possible, désactivation de comptes)
- Sauvegarder les preuves (logs, courriels, journaux)
- Alerter les prestataires concernés (hébergeur, éditeur de logiciel)

Étape 4 — Évaluation du risque

Dans les 24 à 48 heures, la Directrice (avec l'appui de la DPO (Pascale DAUGÉ)) évalue l'ampleur et le risque :

Critère	Questions à se poser
Volumétrie	Combien de personnes concernées ? Volume de données ?
Nature des données	Données sensibles (santé, sensibles au sens art. 9) ? Mineurs ?
Origine	Interne / externe ? Malveillance / accident ?
Conséquences potentielles	Usurpation d'identité ? Discrimination ? Préjudice moral ? Préjudice financier ?
Mesures compensatoires	Données chiffrées ? Sauvegarde disponible ? Fuite limitée ?

Étape 5 — Décision de notification à la CNIL

Sur la base de l'évaluation :

- Si AUCUN RISQUE identifié pour les personnes : pas de notification, mais consignation au registre des violations
- Si RISQUE identifié : notification à la CNIL sous 72h via le téléservice dédié (www.cnil.fr)
- Si RISQUE ÉLEVÉ : notification CNIL + information individuelle des personnes concernées

Étape 6 — Notification à la CNIL (si requise)

La notification s'effectue via le téléservice dédié sur www.cnil.fr, dans un délai de 72 heures suivant la prise de connaissance. Elle comporte :

- Nature de la violation
- Catégories et nombre approximatif de personnes concernées
- Catégories et volume de données concernées
- Conséquences probables
- Mesures prises ou envisagées pour y remédier
- Coordonnées du DPO (Pascale DAUGÉ, Directrice)

En cas de dépassement des 72h

Si la notification ne peut pas être faite dans les 72h, elle doit néanmoins être adressée, en justifiant du retard. Ne pas notifier du tout est plus grave que de notifier en retard avec justification.

Étape 7 — Information des personnes (si risque élevé)

Si le risque pour les personnes est élevé, la MFR les informe individuellement dans les meilleurs délais, sauf exceptions (article 34.3 RGPD). Le message doit être :

- Écrit en langage clair et simple
- Décrire la nature de la violation
- Indiquer les conséquences probables
- Détailler les mesures prises et à prendre
- Fournir un contact pour toute question

Étape 8 — Consignation au registre des violations

Toute violation, notifiée ou non, est consignée dans le registre interne des violations. Ce registre contient :

- Numéro d'ordre et date
- Description des faits
- Personnes et données concernées
- Décision quant à la notification CNIL (motivée)
- Décision quant à l'information des personnes
- Mesures correctives mises en œuvre
- Suivi et clôture

Étape 9 — Retour d'expérience et amélioration

Chaque violation, même mineure, doit donner lieu à une analyse :

- Pourquoi la violation a-t-elle pu survenir ?
- Quelles mesures techniques ou organisationnelles auraient pu l'éviter ?
- Quelle action de sensibilisation prévoir pour le personnel ?
- Faut-il modifier la présente procédure ?

4. Fiche de signalement (à photocopier ou imprimer)

FICHE DE SIGNALEMENT D'UNE VIOLATION DE DONNÉES

1. IDENTIFICATION

Date de découverte : _____ Heure : _____

Personne ayant fait la découverte : _____

Fonction : _____

2. DESCRIPTION DES FAITS

Nature de l'incident (perte, vol, divulgation, altération, destruction, autre) :

3. CIRCONSTANCES

4. PÉRIMÈTRE ESTIMÉ

Système ou traitement concerné : _____

Nombre estimé de personnes concernées : _____

Types de données concernées : _____

5. MESURES D'URGENCE PRISES

Signature :

Date : _____